How MediChain is built

Architecture

Layer	Technology
Patient app and staff portal	React 18, TypeScript, Vite; installable web apps (PWA) for phone and desktop
Server	Rust (Actix-web): 500+ endpoints; every request is checked against a verified session and the caller's role and relationship to the patient
Data	PostgreSQL 16; encrypted clinical documents stored in the database
Real time	Server-sent events, delivered only to the accounts an event concerns
Cryptography	ChaCha20-Poly1305, Argon2id, Ed25519-signed audit batches
Hosting	AWS af-south-1 (Cape Town): EC2 behind Caddy with automatic HTTPS; S3 for backups and write-once audit checkpoints; CloudWatch alarms

Emergency path

1. The responder picks the facility's approved device and opens a professional work context.
2. They scan the patient's QR (any camera: built-in detector where available, a bundled decoder elsewhere), tap an NFC card (Web NFC on Android), or type the card number.
3. The server checks the device, the work context and the card or signed QR proof, then issues a time-limited emergency grant.
4. The summary is shown; the disclosure is written to the audit stream, and the patient sees it in their access history.
5. With no connection, the QR's own printed summary is shown, labelled unverified and unrecorded.

Measured quality

1,045 server tests passing

855 staff-portal tests

280 patient-app tests

35 automated code checks

- **Role journeys:** 276 steps across all seven roles fill in each role's forms with the page's own data and read the result back as a different user. The one defect this found (consent signing) was fixed the same day.
- **Live check:** a script tests the live site: HTTPS certificate, security headers and content security policy, then signs in as every reviewer account and opens every screen it may reach. It passed 24 of 24 checks.
- **Browser tests:** real-browser tests cover emergency QR scanning with a camera, live messaging on a phone-sized screen, notification history and cross-role workflows.
- **Gates in CI** refuse, among others: an unauthorised endpoint, a form that saves without confirming, a form that sends values nobody entered, and unreadable colour contrast.

Clinical logic

Clinical scores and alerts (for example qSOFA, drug interactions and lab-trend flags) are computed on the server by explicit rules, so every result can be explained. MediChain does not use a predictive model, and an unmeasured value is shown as unknown, never as zero.

Test counts measured 20 October 2026.